UNIT 3 · TOPIC 3.2

Protecting Networks: Managerial Controls and Wireless Security

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following is an example of a managerial control used to govern network security?

- ○ A. Installing a next-generation firewall at the network perimeter
- ○ B. Enabling WPA3 encryption on all wireless access points
- **● C. Publishing an acceptable use policy that outlines permitted network activities**
- ○ D. Running an Nmap scan to inventory active hosts on the network

Correct answer: C

Why: Managerial controls are administrative in nature, policies, procedures, training, and governance frameworks. An acceptable use policy (AUP) specifies rules for permitted activities and is a canonical managerial control. Firewalls, WPA3 configuration, and Nmap scans are technical or operational controls, not administrative ones.

*Why the others are wrong: **A**, Students may conflate firewall policy rules with the broader category of policy-as-governance. Firewall rules are configurations inside a technical system, not administrative mandates. **B**, WPA3 is a wireless encryption protocol implemented in hardware and software. Choosing or configuring it is a technical control decision, even if mandated by a managerial policy. **D**, Nmap is an operational tool used for reconnaissance and inventory. Its use may be authorized by policy, but the scanning tool itself is a technical/operational control.*

2. A school district mandates that all staff complete annual network security awareness training before accessing district systems. Which risk-management function does this training most directly serve?

- ○ A. Detecting anomalous network traffic in real time
- ○ B. Encrypting data transmitted across the wireless network
- **● C. Reducing the likelihood of human-error-based security incidents**
- ○ D. Segmenting the staff network from the student network

Correct answer: C

Why: Security awareness training is a managerial control whose primary risk-management function is reducing human-related risk, phishing susceptibility, accidental misconfiguration, and susceptibility to social engineering. Detection, encryption, and segmentation are technical controls; they are not outcomes of a training program.

*Why the others are wrong: **A**, Real-time anomaly detection is a detective technical control (e.g., IDS/IPS, SIEM). Training cannot observe or flag live traffic. **B**, Wireless encryption is a preventive technical control configured on access points and end devices. Training does not configure protocols. **D**, Network segmentation is an architectural decision implemented through VLANs and routing rules. It is independent of training programs.*

3. A network manager schedules a periodic review of all wireless access point configurations to verify compliance with the organization's security policy. This activity is best classified as which type of risk-management control?

- ○ A. Corrective control
- **● B. Detective managerial control**
- ○ C. Deterrent control
- ○ D. Technical preventive control

Correct answer: B

Why: A scheduled compliance review is an auditing activity, it detects drift from policy (detective) and relies on governance processes rather than automated technical mechanisms (managerial). Corrective controls remediate confirmed problems after the fact. Deterrent controls discourage attacks by making them seem less rewarding (e.g., warning banners). Technical preventive controls block attacks automatically through software or hardware.

*Why the others are wrong: **A**, Corrective controls act after a compromise is confirmed, such as reimaging a compromised device or revoking a certificate. Scheduling a review is not itself a corrective action. **C**, Deterrent controls discourage behavior, typically through signage, warning messages, or visible enforcement. A configuration review does not deter; it detects. **D**, Technical preventive controls (firewall rules, IDS signatures) are automated. A human-driven, calendar-scheduled review is administrative and managerial by nature.*

4. A university Wi-Fi network uses WPA2-Personal with a shared passphrase posted in every classroom. A security consultant determines this exposes students to credential theft via offline dictionary attacks. Which change would most directly reduce this risk?

- **● A. Switching to WPA2-Enterprise with 802.1X per-user authentication**
- ○ B. Increasing the shared passphrase length to at least 20 characters
- ○ C. Hiding the network SSID so it does not appear in device scan lists
- ○ D. Enabling MAC address filtering on all wireless access points

Correct answer: A

Why: WPA2-Personal derives session keys from a shared PSK that any client who captures a handshake can attack offline. WPA2-Enterprise with 802.1X issues per-user credentials authenticated through a RADIUS server; there is no shared secret to capture or brute-force. A longer passphrase raises the cost of an offline attack but does not eliminate the fundamental shared-secret vulnerability. SSID hiding is trivially defeated by passive monitoring of probe requests. MAC addresses are broadcast in plaintext and easily spoofed, so MAC filtering does not prevent credential theft.

*Why the others are wrong: **B**, A longer passphrase meaningfully raises attack cost but does not remove the shared-key model. A determined attacker with GPU resources can still run dictionary or brute-force attacks against a captured WPA2 handshake. **C**, SSID hiding stops the AP from broadcasting its name but does not affect the authentication mechanism. The network remains discoverable via passive monitoring of probe requests from devices seeking it. **D**, MAC filtering maintains an allowlist of hardware addresses but MAC addresses are transmitted in plaintext. An attacker can spoof a permitted MAC address after passively observing traffic, bypassing the filter entirely.*

5. An organization implements a BYOD policy requiring all employee-owned devices to run approved endpoint security software before connecting to the corporate wireless network. Which of the following best explains how this managerial control reduces insider threat risk?

- ○ A. It blocks unauthorized devices from associating with the access point via MAC address filtering
- **● B. It ensures devices meet a minimum security baseline, reducing the attack surface available to malicious or negligent insiders**
- ○ C. It encrypts all wireless traffic between employee devices and the access point
- ○ D. It automatically segments employee devices onto a dedicated VLAN

Correct answer: B

Why: The BYOD policy as described is a managerial control, it establishes a governance requirement. By mandating approved endpoint security software, it reduces the risk that an unpatched or compromised device, whether used intentionally or accidentally by an insider, introduces vulnerabilities onto the corporate network. Options A, C, and D describe technical controls that may accompany the policy, but they are not what the written policy itself does.

*Why the others are wrong: **A**, MAC filtering is a separate, hardware-level technical control configured on the access point. A BYOD policy document does not implement or enforce MAC filtering. **C**, Wireless traffic encryption is controlled by the network's configured security protocol (WPA2/WPA3), not by a written policy. The policy may mandate a protocol, but the encryption itself is a technical control. **D**, VLAN segmentation is a network architecture decision implemented through switches and AP configuration. A BYOD policy may require it, but the segmentation itself is a technical control.*

6. A network administrator disables SSID broadcast on a guest wireless network as a wireless security measure. Which statement most accurately describes the actual effect of this configuration on the network's risk profile?

- ○ A. It prevents all unauthorized users from discovering the network because unlisted networks are not visible to scanning tools
- ○ B. It qualifies as a managerial control because hiding the SSID is a documented configuration decision
- ○ C. It eliminates the need for WPA2 or WPA3 encryption because undiscoverable networks cannot be targeted

● **D. It provides minimal security improvement because the SSID remains discoverable through passive analysis of probe request frames**

Correct answer: D

Why: SSID hiding prevents the access point from announcing its name in beacon frames, but devices actively seeking a known hidden network transmit the SSID in probe request frames. Tools such as Wireshark and Kismet can read these in plaintext, making the network trivially discoverable. SSID hiding is security through obscurity, negligible real protection. It does not remove the need for encryption, and documenting a technical setting does not reclassify it as a managerial control.

*Why the others are wrong: **A**, This overestimates SSID hiding. Passive monitoring of probe requests from any device already configured with the hidden SSID's name reveals it immediately. Active scanners also detect the AP's presence even without a named beacon. **B**, A control's type is defined by its mechanism, not by whether it was written down. Documenting a technical configuration decision does not convert a technical control into a managerial one. **C**, SSID visibility is entirely separate from the authentication and encryption layer. An open (unencrypted) network with a hidden SSID transmits all traffic in plaintext, readable by anyone in radio range who discovers it, regardless of obscurity.*

7. A National Guard technician must configure emergency Wi-Fi at a disaster shelter. Available hardware supports both WPA2-Personal and WPA3-Enterprise. Shelter residents will use personal devices; no on-site RADIUS server infrastructure is available and sourcing one before the shelter opens is not feasible. Evaluating risk-management trade-offs, which configuration best balances security and operational feasibility?

○ A. WPA3-Enterprise, because per-user 802.1X credentials eliminate the shared-key vulnerability entirely regardless of infrastructure constraints

○ B. WPA2-Personal with the passphrase publicly displayed at the shelter entrance so all residents can connect without assistance

● **C. WPA2-Personal with a strong randomly-generated passphrase, combined with guest VLAN segmentation and a posted acceptable use policy for residents**

○ D. Wi-Fi Enhanced Open (OWE) under WPA3, since it provides opportunistic encryption and removes the passphrase barrier for displaced residents

Correct answer: C

Why: WPA3-Enterprise is the technically strongest option, but it requires 802.1X/RADIUS infrastructure not available in this scenario, choosing it without infrastructure means the network either cannot operate or falls back to WPA2. Sound risk management requires evaluating feasibility alongside security. WPA2-Personal with a strong non-public passphrase, guest VLAN segmentation (isolating residents from each other's devices), and an AUP constitutes a practical layered defense. Option B recreates exactly the shared-key exposure problem. Wi-Fi Enhanced Open (OWE) provides per-session opportunistic encryption but no authentication, anyone can join, including adversaries capable of staging man-in-the-middle attacks on the unverified connections.

*Why the others are wrong: **A**, WPA3-Enterprise is technically ideal but operationally infeasible without RADIUS/802.1X infrastructure. Selecting a control that cannot be deployed does not reduce risk, it leaves the network unsecured. NIST SP 800-30 Risk Management guidance requires feasibility to be part of control selection. **B**, Displaying the passphrase publicly creates an open shared secret. Any attacker in radio range can capture a WPA2 handshake and, with the visible passphrase in hand, decrypt all network traffic retroactively. **D**, OWE encrypts each session opportunistically but provides no authentication, any device can join. An attacker can connect freely and position themselves for man-in-the-middle attacks between residents and the internet gateway. It is not a suitable single control for a network with residents who may be communicating sensitive personal information.*

8. A small company's entire wireless security program consists of a written BYOD policy stating that personal devices must only be used for work tasks. No technical controls, no network access control, no endpoint detection, no wireless intrusion detection, are deployed. Evaluating the effectiveness of this risk-management strategy, which conclusion is most accurate?

○ A. The policy is sufficient because managerial controls form the highest tier of the security control hierarchy and set the intent that all other controls serve

○ B. The policy is sufficient if all employees sign an acknowledgment form, because that creates enforceable legal accountability for violations

● C. The policy is insufficient because without complementary technical controls, compliance cannot be enforced, monitored, or verified

○ D. The policy is sufficient for small companies because threat actors typically focus resources on larger, more profitable targets

Correct answer: C

Why: Managerial controls set expectations and create accountability, but without technical controls they cannot be enforced or monitored. A policy relying solely on signed acknowledgments depends entirely on voluntary compliance, leaving no mechanism to detect or prevent violations. NIST SP 800-12 and NIST SP 800-53 both treat managerial, operational, and technical controls as complementary, no single layer is sufficient. NIST SP 800-53 explicitly defines control families across all three types to work in combination.

*Why the others are wrong: **A**, There is no established security framework in which managerial controls are independently sufficient. NIST SP 800-53 and the Defense-in-Depth model both explicitly require technical and operational controls alongside managerial ones. **B**, Signed acknowledgments create legal liability, not security. A disgruntled employee or an employee with poor security hygiene can still connect an unmanaged device, the signed form does not detect or block the action. **D**, Small organizations are frequently targeted precisely because their controls are weaker. Threat actors actively scan for low-hanging fruit. Assuming small-company immunity contradicts documented incident statistics and NIST guidance on threat modeling.*

9. A network security manager selects risk-management strategies for a hospital's wireless network. Three options are under consideration: Option 1, WPA3-Enterprise encryption only, no written governance policies. Option 2, Written wireless governance policies only, no encryption upgrade from the current WPA2-Personal. Option 3, WPA3-Enterprise encryption combined with a wireless device governance policy. Using NIST SP 800-12 principles, which ranking of these options is most defensible?

○ A. Option 1 > Option 2 > Option 3, because technical controls are inherently more effective than managerial ones and combining them introduces policy overhead without additional protection

● B. Option 3 > Option 1 > Option 2, because layered controls address both technical vulnerabilities and behavioral or governance gaps that neither control type resolves alone

○ C. Option 2 > Option 3 > Option 1, because governance frameworks establish the authorization structure that gives technical controls their legitimacy and should be prioritized first

○ D. All three options are equivalent for a hospital network because any single well-implemented control, whether technical or managerial, is sufficient given appropriate funding

Correct answer: B

Why: Option 3 implements defense-in-depth: WPA3-Enterprise eliminates shared-key vulnerabilities and enforces per-user authentication, while the governance policy ensures devices are authorized, access is documented, and incidents are handled consistently. Option 1 alone leaves behavioral and governance risks unaddressed, unauthorized devices, undocumented access, and no change-management process. Option 2 alone cannot be technically enforced or verified. NIST SP 800-12 Section 3 explicitly states that security programs require management, operational, and technical controls in combination. For a hospital, both HIPAA Security Rule requirements and NIST guidance on healthcare environments reinforce this layered approach.

*Why the others are wrong: **A**, Technical and managerial controls address different attack surfaces. A technically hardened network with no governance policies is vulnerable to insider threats, unauthorized device connections, and unmanaged configuration changes that go undocumented and unreviewed. **C**, While governance frameworks provide the authorization structure for technical controls, Option 2, policy without any technical implementation, cannot enforce, verify, or detect compliance. Prioritizing policy alone and ranking it above a combined approach contradicts NIST SP 800-12's position on layered controls. **D**, No security framework supports the claim that a single control is sufficient for a sensitive environment. NIST SP 800-12 and NIST SP 800-53 are built on the premise that security requires complementary, overlapping controls. A single point of protection is a single point of failure.*

10. When configuring WPA2 security on a wireless access point, which of the following settings must a technician explicitly configure to enable encryption?

○ A. The network's SSID broadcast name

○ B. The maximum number of simultaneous device connections

● C. The encryption passphrase or pre-shared key (PSK)

○ D. The radio channel and bandwidth (e.g., 2.4 GHz vs 5 GHz)

Correct answer: C

Why: WPA2 encryption requires a PSK (in Personal mode) or 802.1X credentials (in Enterprise mode) as the basis for deriving session encryption keys. The SSID names the network but is independent of encryption. Maximum connection counts affect throughput capacity. Radio channel and bandwidth control signal frequency allocation. None of the other options enable or configure the encryption mechanism.

*Why the others are wrong: **A**, The SSID identifies the network by name but plays no role in encryption. A network can have an SSID and no encryption at all (open network), or hide its SSID while still using WPA2. **B**, Maximum connection limits manage network load and performance; they have no relationship to the authentication or encryption configuration. **D**, Channel and bandwidth settings govern radio frequency use to reduce interference and manage throughput. They are independent of the security protocol layer.*

11. After changing the wireless encryption standard on a corporate access point from WPA2 to WPA3, which action should the technician take to properly document the mitigation?

● A. Record the change in a configuration change log with the date, change description, and technician name

○ B. Send an all-staff email announcing that a wireless security upgrade has been completed

○ C. Run a packet capture to confirm that WPA3-encrypted frames are visible on the network

○ D. Reboot the access point to ensure the new configuration is applied

Correct answer: A

Why: Logging a mitigation means creating a documented record of who made the change, what was changed, and when, fulfilling the accountability and traceability requirements of skill 2.D. A configuration change log with these fields supports audit trails, compliance verification, and incident response. Emailing staff is a communication action, not a log entry. Running a packet capture verifies the technical outcome but is not documentation of the change itself. Rebooting applies the configuration but does not record it.

*Why the others are wrong: **B**, User notification is a communication step, not documentation. Change logs and communication serve different purposes and one does not substitute for the other. **C**, A packet capture can verify the change worked and may be referenced in the log, but it is a verification artifact, not the log entry itself. **D**, Rebooting is an operational step to make the configuration active. It does not create any record of the change for audit purposes.*

12. A technician wants to implement MAC address filtering on a wireless network. Which of the following correctly describes how this mitigation is configured?

○ A. The technician upgrades the wireless encryption protocol from WPA2 to WPA3

● B. The technician enters the hardware MAC addresses of permitted devices into an access control list on the wireless access point

○ C. The technician assigns each permitted device a static IP address through DHCP reservations

○ D. The technician reduces the access point's transmit power to limit the wireless signal's physical coverage area

Correct answer: B

Why: MAC address filtering works by maintaining an allowlist (or denylist) of hardware MAC addresses in the access point's administration interface. Frames from unlisted MAC addresses are dropped. This is a Layer 2 access control. WPA3 is an encryption/authentication upgrade, not an address-based filter. DHCP reservations assign predictable IPs but do not block unlisted devices from associating with the AP. Reducing transmit power limits coverage range but does not authenticate or filter devices.

*Why the others are wrong: **A**, WPA3 improves authentication and encryption but does not filter by device hardware address. A device with an unknown MAC address can still attempt to authenticate under WPA3. **C**, DHCP reservations ensure known devices get predictable IP*

addresses but do not prevent an unlisted device from associating at the wireless layer and obtaining a dynamic IP lease. ***D****, Reducing transmit power is a physical layer measure to contain signal spread. A nearby attacker with a directional antenna can still reach a low-power AP from outside the intended coverage area, and in-range devices are still not filtered by address.*

13. A National Guard technician is configuring a new consumer-grade wireless access point for a disaster shelter. The following steps must be completed: (I) Set a strong WPA2-Personal passphrase. (II) Change the default administrator password on the access point management interface. (III) Disable WPS (Wi-Fi Protected Setup). (IV) Enable the SSID so residents can discover and connect to the network. Which sequence correctly reflects secure implementation practice?

○ A. IV → I → III → II

○ B. III → IV → I → II

○ C. I → II → IV → III

● D. II → I → III → IV

Correct answer: D

Why: Secure configuration sequencing begins with locking down management access: change the default admin password (II) first, so no one who knows the manufacturer default can reconfigure the device during setup. Then set the encryption passphrase (I) so the network's security is in place before it goes live. Disable WPS (III) next, WPS has a known PIN brute-force vulnerability (Pixie Dust / Reaver attacks) and should be disabled before the network is discoverable. Finally, enable the SSID (IV) to bring the network live only after all security settings are confirmed. Enabling the SSID earlier (options A, C, D) exposes the network while it is in an insecure transitional state.

Why the others are wrong: ***A****, Enabling the SSID first makes the network discoverable before encryption and management lockdown are complete. Any device in range could attempt to connect or probe the management interface with default credentials.* ***B****, Starting with WPS disable is not harmful, but deferring the admin password change to the very end leaves the management interface open with default credentials throughout the entire configuration process.* ***C****, Setting the passphrase before changing the default admin password leaves the management interface accessible with known default credentials during setup. An attacker who reaches the admin interface during this window can override all subsequent settings.*

14. A technician configuring WPA2 on a corporate wireless network must choose between the TKIP and CCMP (AES) cipher suites. Which cipher suite should be selected and why?

○ A. TKIP, because it was the original WPA cipher and provides the broadest compatibility with legacy wireless devices on the network

● B. CCMP (AES), because TKIP has documented cryptographic weaknesses and CCMP provides stronger, standards-compliant encryption

○ C. TKIP, because it uses a 256-bit key, making it cryptographically stronger than CCMP's shorter key

○ D. CCMP (AES), but only if the network has more than 50 concurrently connected devices, since AES adds processing overhead on smaller networks

Correct answer: B

Why: TKIP (Temporal Key Integrity Protocol) was a transitional cipher designed to run WPA security on older WEP-era hardware. It has known weaknesses including the Beck-Tews attack, and the Wi-Fi Alliance deprecated it in 2009. CCMP (Counter Mode Cipher Block Chaining Message Authentication Code Protocol) uses AES-128 and is the mandatory cipher for WPA2 certification. The Wi-Fi Alliance and NIST recommend CCMP exclusively for WPA2. TKIP does not use 256-bit keys, it uses 128-bit RC4-derived keys. The number of connected devices has no bearing on cipher selection: CCMP is preferred at any scale.

Why the others are wrong: ***A****, Legacy device compatibility is a real operational concern, but known cryptographic vulnerabilities make TKIP unsuitable as a primary cipher. Modern devices universally support CCMP; legacy-only devices should be isolated or replaced rather than accepted as justification for a weaker cipher.* ***C****, This is factually incorrect. TKIP uses 128-bit RC4-derived keys with per-packet key mixing, not 256-bit keys. CCMP with AES-128 is stronger than TKIP regardless of raw key-length comparisons because the AES block cipher has no comparable known practical attacks.* ***D****, AES hardware acceleration is standard on all modern access points and client devices. Processing overhead from CCMP is negligible in practice and is not a valid basis for cipher selection on any network size.*

15. A technician upgrades a hospital's wireless network from WPA2-Personal to WPA3-Enterprise. Which of the following log entries most completely fulfills the "log mitigations" requirement for this configuration change?

○ A. "Wi-Fi upgraded."

○ B. "Change made to wireless settings per IT manager instruction."

● C. "WPA3-Enterprise enabled on all access points on 2024-11-15 by J. Kim; prior configuration: WPA2-Personal with PSK; reason: policy compliance requirement and elimination of shared-key authentication risk; verified via successful 802.1X authentication test on two client devices."

○ D. "WPA3 is now active across the hospital network."

Correct answer: C

Why: A complete mitigation log entry must answer: what changed (WPA2-Personal PSK → WPA3-Enterprise 802.1X), when (date), who made the change (technician name), why (reason and policy reference), and how it was verified (802.1X auth test). Options A, C, and D are missing one or more of these fields. NIST SP 800-92 (Guide to Computer Security Log Management) specifies that log entries must include sufficient context to reconstruct and audit the event independently. Without the prior state, reason, and verification, an auditor cannot confirm the change was authorized, necessary, or successful.

*Why the others are wrong: **A**, "Wi-Fi upgraded" identifies the general system but provides no actionable information about what changed, from what, by whom, when, why, or whether it succeeded. It is not a usable audit record. **B**, Naming the authorizing manager is good practice, but without specifying the change itself, the previous state, the implementer's name, the date, and verification, the entry cannot serve as evidence of a specific implemented mitigation. **D**, Stating the current state is useful as a status note but omits the prior state, the change agent, the date, the reason, and verification, making it impossible for an auditor to reconstruct what happened or confirm it was done correctly.*

16. A National Guard technician must deploy and document emergency shelter Wi-Fi under the following constraints: consumer-grade access point only, no RADIUS server, no additional hardware procurement time. Applying NIST SP 800-12 principles for implementing and logging protective controls, which combination of mitigations and documentation most appropriately addresses this situation?

● A. Deploy WPA2-Personal with a strong randomly-generated passphrase, disable WPS, apply guest VLAN segmentation, post a written network acceptable use policy, and log each configuration step with timestamp, action taken, and rationale

○ B. Deploy WPA3-Enterprise and document that no RADIUS server was required because WPA3 is inherently self-authenticating in Enterprise mode

○ C. Deploy the network with no encryption to ensure all displaced residents can connect without technical barriers, and create a detailed post-deployment usage policy

○ D. Deploy WPA2-Personal using factory default settings to minimize setup time, and log the decision to prioritize rapid deployment over security configuration

Correct answer: A

Why: Without a RADIUS server, WPA3-Enterprise cannot be deployed, 802.1X authentication requires server infrastructure. The correct approach layers feasible technical mitigations (strong PSK, WPS disabled, VLAN isolation) with a managerial control (AUP) and fulfills 2.D's logging requirement by documenting each step with timestamps and rationale, creating an audit trail and demonstrating due diligence per NIST SP 800-12 Section 3.2. Option B contains a factual error, WPA3-Enterprise is not self-authenticating; it requires RADIUS. Option C removes encryption entirely, exposing all resident traffic in plaintext. Option D documents a known-insecure configuration, which is logging a risk acceptance, not a mitigation.

*Why the others are wrong: **B**, WPA3-Enterprise requires 802.1X/RADIUS infrastructure by definition, it is not self-authenticating. Logging this claim would create a false audit record, which could have compliance and liability consequences beyond the security failure itself. **C**, Deploying an open, unencrypted network means all resident traffic, personal messages, credentials for family communication services, is readable in plaintext by any device in range. A usage policy does not encrypt data. **D**, Factory defaults on consumer APs include publicly known admin credentials (admin/admin, admin/password, etc.) and often have WPS enabled. Logging a decision to retain factory defaults documents a risk acceptance, not an implemented mitigation, this does not fulfill the "implement mitigations" requirement of skill 2.D.*

17. As part of a NIST-aligned change management process, a technician simultaneously implements two controls: (1) a new network governance policy mandating that all wireless access points use WPA3, and (2) the technical upgrade of all APs to WPA3-Personal. When logging these mitigations, what should the log entry capture to be most useful for a future security audit?

- **● A. Both the policy implementation and the technical change, with cross-references between them, dates, technician and approver names, prior configuration state, verification method, and any devices that could not be upgraded**
- ○ B. Only the technical change, because governance policies are maintained in a separate policy register and do not belong in a configuration change log
- ○ C. Only the policy, because the technical change will be independently detected and recorded by network monitoring tools during routine traffic analysis
- ○ D. A single summary statement confirming that WPA3 is now both policy and deployed, since brevity improves log readability and auditability

Correct answer: A

Why: When a managerial and technical control are implemented together, their log entries must be linked so auditors can verify that the policy was actually implemented technically, and vice versa. An audit-quality log entry must capture: the previous state (what encryption was in use), the new state, dates, who authorized and who implemented, what verification was done, and exceptions (e.g., legacy APs that could not be upgraded to WPA3). NIST SP 800-92 requires logs to be sufficient for independent reconstruction. A summary statement (D) and siloed entries (A, C) all fail this standard in different ways.

*Why the others are wrong: **B**, Siloing governance and technical change records prevents auditors from verifying alignment between stated policy and actual implementation. The gap between "we have a policy" and "we implemented it" is exactly what security audits investigate. **C**, Network monitoring tools record traffic behavior, not configuration intent, authorization, or rationale. Automated detection cannot substitute for a deliberate, authored change log entry that establishes who decided to make the change and why. **D**, Brevity is valuable for executive summaries, not security audit logs. A one-line summary cannot serve as evidence of due diligence, it lacks the specificity (prior state, who, when, verification, exceptions) required for independent reconstruction under NIST SP 800-92.*

18. A security auditor reviews the following wireless configuration change log entry: "Changed encryption on APs to WPA3. — J. Kim, 2024-11-15." The auditor flags the entry as insufficient for audit purposes. Which set of missing elements, if added, would bring this entry into compliance with NIST SP 800-12 documentation standards for logged mitigations?

- **● A. The prior configuration state, the justification or reason for the change, the name of the authorizing approver, and verification evidence that the change was successfully applied**
- ○ B. Only the time of day is missing; date, technician name, and action described are sufficient for a minor configuration change
- ○ C. Only the approver's name and signature are missing; all other required fields are present in the current entry
- ○ D. No elements are missing; a concise log entry is acceptable under NIST guidance for routine low-risk configuration changes

Correct answer: A

Why: The entry includes a change description, a technician name, and a date, but is missing four required components under NIST SP 800-12 change management documentation standards: (1) the prior state (what encryption was previously configured), which establishes the baseline for comparison; (2) the justification (which risk, policy requirement, or incident triggered the change), which establishes authorization context; (3) the approver (who authorized the change), which establishes accountability and the separation of duties; and (4) verification evidence (e.g., successful WPA3 handshake confirmation or 802.1X auth test), which confirms the change achieved its intended effect. NIST SP 800-12 and SP 800-92 both require that logs be "complete and accurate", there is no carve-out for routine or minor changes to security-relevant systems.

*Why the others are wrong: **B**, Missing a precise timestamp is a gap, but far less significant than missing the prior state, justification, approver, and verification. Flagging only the timestamp would leave the entry fundamentally non-compliant with NIST documentation requirements. **C**, The approver name is one of four missing elements. Focusing solely on the approver would leave the prior state, reason, and verification absent, the entry would remain inadequate for independent audit reconstruction. **D**, NIST SP 800-12 does not define a "routine low-risk" carve-out for security configuration changes. Encryption protocol selection is a security-relevant change by definition; its log entry must meet the full standard regardless of whether it is considered routine by the technician.*